	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**18/10/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Auditoría Básica del Sistema con Lynis**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Auditoría Básica del Sistema con Lynis

Instalamos lynis usando uno de los 2 métodos posibles:

1- sudo apt-get install lynis
2- git clone https://github.com/CISOfy/1ynis

Ahora vamos a realizar nuestra auditoría con el programa, para ello usamos el comando **sudo lynis audit system | tee informe_lynis.txt**

tee Sirve para exportar el informe, en este caso a un **TXT**

```
  - Ownership of home directories                                 [ OK ]
  - Checking shell history files                                  [ OK ]

[+] Bastionado del kernel
------------------------------------
  - Comparing sysctl key pairs with scan profile
    - dev.tty.ldisc_autoload (exp: 0)                             [ DIFERENTE ]
    - fs.protected_fifos (exp: 2)                                 [ DIFERENTE ]
    - fs.protected_hardlinks (exp: 1)                             [ OK ]
    - fs.protected_regular (exp: 2)                               [ OK ]
    - fs.protected_symlinks (exp: 1)                              [ OK ]
    - fs.suid_dumpable (exp: 0)                                   [ DIFERENTE ]
    - kernel.core_uses_pid (exp: 1)                               [ OK ]
    - kernel.ctrl-alt-del (exp: 0)                                [ OK ]
    - kernel.dmesg_restrict (exp: 1)                              [ OK ]
    - kernel.kptr_restrict (exp: 2)                               [ DIFERENTE ]
    - kernel.modules_disabled (exp: 1)                            [ DIFERENTE ]
    - kernel.perf_event_paranoid (exp: 3)                         [ DIFERENTE ]
    - kernel.randomize_va_space (exp: 2)                          [ OK ]
    - kernel.sysrq (exp: 0)                                       [ DIFERENTE ]
    - kernel.unprivileged_bpf_disabled (exp: 1)                   [ DIFERENTE ]
    - kernel.yama.ptrace_scope (exp: 1 2 3)                       [ OK ]
    - net.core.bpf_jit_harden (exp: 2)                            [ DIFERENTE ]
    - net.ipv4.conf.all.accept_redirects (exp: 0)                 [ DIFERENTE ]
    - net.ipv4.conf.all.accept_source_route (exp: 0)              [ OK ]
    - net.ipv4.conf.all.bootp_relay (exp: 0)                      [ OK ]
    - net.ipv4.conf.all.forwarding (exp: 0)                       [ OK ]
    - net.ipv4.conf.all.log_martians (exp: 1)                     [ DIFERENTE ]
    - net.ipv4.conf.all.mc_forwarding (exp: 0)                    [ OK ]
```

También se ha generado el informe en el archivo **informe_lynis.txt**

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**18/10/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Auditoría Básica del Sistema con Lynis**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Ahora vamos a instalar **fail2ban**. Para ello usamos el comando **sudo apt-get install fail2ban** y verificamos que se ha instalado sin problemas con **sudo systemctl status fail2ban**

```
Preparando para desempaquetar .../whois_5.5.13_amd64.deb ...
Desempaquetando whois (5.5.13) ...
Configurando whois (5.5.13) ...
Configurando fail2ban (0.11.2-6) ...
Configurando python3-pyinotify (0.9.6-1.3) ...
Procesando disparadores para man-db (2.10.2-1) ...
angel@angel-VirtualBox:~/Documentos$ sudo systemctl status fail2ban
○ fail2ban.service - Fail2Ban Service
     Loaded: loaded (/lib/systemd/system/fail2ban.service; disabled; vendor preset: enabled)
     Active: inactive (dead)
       Docs: man:fail2ban(1)
angel@angel-VirtualBox:~/Documentos$
```

fail2ban A groso modo es un set de programas de cliente y servidor que limita los intentos de autenticación para evitar los ataques de fuerza bruta.

<u>Comprueba si Lynis sugiere que se agregue un banner legal en el archivo /etc/issue para advertir a los usuarios no autorizados.</u>

Ahora vamos a comprobar si en el informe nos recomienda un banner legal en dicho archivo.

```
angel@angel-VirtualBox:~/Documentos$ sudo cat informe_lynis.txt | grep /etc/issue
[sudo] contraseña para angel:
  - /etc/issue                                                [ ENCONTRADO ]
    - /etc/issue contents                                     [ DÉBIL ]
  - /etc/issue.net                                            [ ENCONTRADO ]
    - /etc/issue.net contents                                 [ DÉBIL ]
    File: /etc/issue                                          [ OK ]
    File: /etc/issue.net                                      [ OK ]
  * Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
  * Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
angel@angel-VirtualBox:~/Documentos$
```

Para generar el banner usamos **sudo nano /etc/issue**

```
angel@angel-VirtualBox: ~/Documentos
angel@angel-VirtualBox: ~/Documentos        angel@angel-VirtualB
  GNU nano 6.2                                  /etc/issue *
¡ATENCIÓN! Este es un sistema privado. El acceso no autorizado está prohibido.
Cualquier actividad será registrada.
Ubuntu 22.04.5 LTS \n \l
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**18/10/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Auditoría Básica del Sistema con Lynis**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Ahora vamos a comprobar si tenemos cuentas de usuario sin contraseña, para ello usamos el comando **sudo passwd -S -a | grep -E '\sNP\s'**
En mi caso no ha salido ninguno, por lo que he creado un usuario sin contraseña usando el comando **sudo useradd -p '' fulanito**

Ahora volvemos a ejecutar el comando y nos saldrá el usuario sin contraseña.

```
angel@angel-VirtualBox:~/Documentos$ sudo passwd -S -a | grep -E '\sNP\s'
fulanito NP 10/18/2024 0 99999 7 -1
angel@angel-VirtualBox:~/Documentos$
```

sudo passwd -S -a | grep -E '\sNP\s'
-S Sirve para ver el estado de los usuarios
-a Todos los usuarios

-E en grep Sirve para que haga una búsqueda multiples coincidencias con el patrón de búsqueda.

Ahora vamos a asignarle una contraseña a **fulanito** con el comando **sudo passwd fulanito**
Nos pedirá la contraseña 2 veces, el mensaje de incorrecta que muestra es porque he usado de contraseña el mismo nombre de usuario. Ni caso porque es una prueba.

```
angel@angel-VirtualBox:~/Documentos$ sudo passwd fulanito
Nueva contraseña:
CONTRASEÑA INCORRECTA: De alguna manera, en la contraseña se lee el nombre del usuario
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
angel@angel-VirtualBox:~/Documentos$
```

<u>Verificar presencia de Firewall</u>
Vamos a comprobar si existe un Firewall activo, para ello usamos el comando **sudo ufw status**
En este caso nos dice que **inactivo** por lo que vamos a activarlo usando el comando **sudo ufw enable**

```
angel@angel-VirtualBox:~/Documentos$ sudo ufw status
Estado: inactivo
angel@angel-VirtualBox:~/Documentos$ sudo ufw enable
El cortafuegos está activo y habilitado en el arranque del sistema
angel@angel-VirtualBox:~/Documentos$ sudo ufw status
Estado: activo
angel@angel-VirtualBox:~/Documentos$
```

<u>Explica brevemente la utilidad la herramienta ufw.</u>
Está diseñado para facilitar la configuración y el uso del firewall en Linux, especialmente para usuarios que no están familiarizados con iptables.

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**18/10/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Auditoría Básica del Sistema con Lynis**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Verificar con lynis las mejoras efectuadas

He vuelto a generar la auditoría con el usuario sin contraseña para el **informe_lynis.txt** y sale exactamente igual que en la auditoría posterior del usuario CON CONTRASEÑA cifrada para el informe **informe_lynis_post_mejoras.txt** (No salen diferencias)

```
angel@angel-VirtualBox:~/Documentos$ sudo cat informe_lynis.txt | grep password
    - Checking for password protection                          [ NINGUNO ]
        - systemd-ask-password-console.service:                 [ INSEGURO ]
        - systemd-ask-password-plymouth.service:                [ INSEGURO ]
        - systemd-ask-password-wall.service:                    [ INSEGURO ]
  - Checking password hashing rounds                            [ DESHABILITADO ]
  - PAM password strength tools                                 [ OK ]
  - Accounts without password                                   [ OK ]
  - Checking user password aging (minimum)                      [ DESHABILITADO ]
  - User password aging (maximum)                               [ DESHABILITADO ]
  - Checking expired passwords                                  [ OK ]
  * Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode wit
hout password) [BOOT-5122]
  * Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values [AUTH-9229
]
  * Configure password hashing rounds in /etc/login.defs [AUTH-9230]
  * When possible set expire dates for all password protected accounts [AUTH-9282]
  * Configure minimum password age in /etc/login.defs [AUTH-9286]
  * Configure maximum password age in /etc/login.defs [AUTH-9286]
angel@angel-VirtualBox:~/Documentos$
```

```
angel@angel-VirtualBox:~/Documentos$ sudo cat informe_lynis_post_mejoras.txt | grep password
    - Checking for password protection                          [ NINGUNO ]
        - systemd-ask-password-console.service:                 [ INSEGURO ]
        - systemd-ask-password-plymouth.service:                [ INSEGURO ]
        - systemd-ask-password-wall.service:                    [ INSEGURO ]
  - Checking password hashing rounds                            [ DESHABILITADO ]
  - PAM password strength tools                                 [ OK ]
  - Accounts without password                                   [ OK ]
  - Checking user password aging (minimum)                      [ DESHABILITADO ]
  - User password aging (maximum)                               [ DESHABILITADO ]
  - Checking expired passwords                                  [ OK ]
  * Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode wit
hout password) [BOOT-5122]
  * Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values [AUTH-9229
]
  * Configure password hashing rounds in /etc/login.defs [AUTH-9230]
  * When possible set expire dates for all password protected accounts [AUTH-9282]
  * Configure minimum password age in /etc/login.defs [AUTH-9286]
  * Configure maximum password age in /etc/login.defs [AUTH-9286]
angel@angel-VirtualBox:~/Documentos$
```

Y exactamente lo mismo con el **firewall** (Me sale activo antes de activarlo localmente y después, se me ocurre que pueda ser que reconoce el **firewall** de la conexión de **murciaeduca)**

```
angel@angel-VirtualBox:~/Documentos$ sudo cat informe_lynis.txt | grep firewall
[+] Software: firewalls
  - Checking host based firewall                                [ ACTIVO ]
angel@angel-VirtualBox:~/Documentos$ sudo cat informe_lynis_post_mejoras.txt | grep firewall
[+] Software: firewalls
  - Checking host based firewall                                [ ACTIVO ]
angel@angel-VirtualBox:~/Documentos$
```